

KUBERNETES IN PRODUCTION · ISSUE 07 OF 08

Secrets management patterns.

The vault is the source of truth. The cluster only
borrows.

07

AR

Akhilesh Ranjan Singh

Senior DevSecOps Engineer · github.com/iarsingh

Swipe →

START HERE

Base64 is encoding, not encryption.

Anyone who can read the Secret object can read the secret.



Options compared

PATTERN	HOW IT WORKS
Native Secret + etcd encryption	Simple; still lives in the cluster
External Secrets Operator	Syncs from Key Vault / Secret Manager
Secrets Store CSI driver	Mounts from the vault as files
Sealed Secrets / SOPS	Encrypted values safe to keep in Git

A pattern I like

- 1 Cloud vault
- 2 Workload identity
- 3 External Secrets
- 4 K8s Secret
- 5 Pod volume

No static cloud credentials in the cluster. Rotation happens in the vault.



Leaks that still happen

DO

- ✓ Workload identity, not key files
- ✓ Mount as volumes so rotation lands
- ✓ Restrict get/list on secrets
- ✓ Scan repos and images for secrets

AVOID

- ✗ Secrets in Helm values in Git
- ✗ Printing env vars in logs
- ✗ Long-lived service account keys
- ✗ One secret shared by every app

Rotation readiness

- ☒ Every secret has an owner
- ☒ Rotation is automated or calendared
- ☒ Apps reload without redeploy
- ☒ Old versions disabled after rotation
- ☒ Access to secrets is audited



KEY TAKEAWAY

Keep secrets in the vault, identities in the cluster.

- Base64 is not protection
- Workload identity over static keys
- Plan rotation before you need it

YOUR TURN

How long would it take you to rotate every production secret today?

FOLLOW AKHILESH RANJAN SINGH

Next in the series: #08 Helm, cluster upgrades and the production checklist

Save · Repost

